

ACTIVIDAD 1 HACKER WOMEN COUNCIL - ETHICAL HACKING	
NOMBRE	Yorbelys Ordonez
CASO	Aurora Market

Analisis y Planificacion del Pentest (Caso Aurora Market)

Objetivo del Pentest.

1. Identificar posibles vulnerabilidades de seguridad en la Aplicación Web de Aurora Market que pueden ser aprovechadas por el atacante y comprometer la confidencialidad, Integridad o disponibilidad de la información.
2. Evaluar el Nivel de Riesgo de las Vulnerabilidades identificadas, considerando la probabilidad de Explotación y el impacto que podrían generar sobre la información y las operaciones de Aurora Market.
3. Proponer Medidas de Mitigación y recomendaciones de seguridad para las vulnerabilidades identificadas priorizando aquello que representa un mayor riesgo para Aurora Market.

Analisis de los objetivos de Pentest:

El objetivo de realizar este pentest a Aurora Market es conocer qué tan segura se encuentra realmente su aplicación Web y detectar posibles debilidades sino de entender que podría pasar si alguien llegara a explotarlas y cómo esto podría afectar a la empresa a sus usuarios o la información que ella maneja.

Por ejemplo si queremos comprobar si existen fallas en su inicio de sesión en los permisos de los diferentes usuarios, los controles de acceso o la forma en la que la aplicación recibe y procesa información de sus clientes, si encontramos alguna debilidad analizaremos qué tan grave sería la magnitud de lo encontrado y cuál debería ser prioridad para corregirse de inmediato.

Este pentest es de gran valor para empresa porque le permitirá conocer sus puntos débiles desde el atacante desde una manera controlada y previamente autorizada. Con estos resultados obtenidos pueden tomar las medidas correspondientes para corregir las vulnerabilidades encontradas, reducir riesgos y fortalecer la seguridad de su aplicación y de la información de sus clientes.

Alcance

- **Si se Evalúa:** Aurora Market solo indico que se evaluará únicamente la aplicación Web. Las Funcionalidades accesibles para los Usuarios y los mecanismos de autenticación y control de acceso asociados a la aplicación.
- **Fuera del Alcance:** Sistemas o servidores internos que no hayan sido expresamente autorizados. Equipos Personales o Corporativos de IOS empleados. Correos Electrónicos y otros servicios corporativos ajenos a la aplicación evaluada. Cualquier Infraestructura o Activo de terceros que no forme parte de Aurora Market.

Autorización y Condiciones

- **Permisos Requeridos:** Antes de iniciar el Pentest se debe contar con una autorización formal por escrito de Aurora Market en la que se establezca el Alcance, las actividades permitidas, las restricciones y las condiciones de evaluación.
- **Condiciones Acordadas:** No interrumpir el servicio ni afectar la disponibilidad de la aplicación. No modificar ni eliminar información Real de los Clientes. Realizar las pruebas preferiblemente en horarios de menor actividad para reducir

el impacto sobre las operaciones. Comunicar inmediatamente a Aurora Market cualquier vulnerabilidad o hallazgo crítico identificado.

Tipo de Pentest.

Gray-Box:

Ya que el equipo dispone de información limitada sobre el entorno de Aurora Market. Solo se conoce la existencia de la aplicación Web, la base de Datos y un mecanismo de autenticación y diferentes tipos de usuarios pero no cuenta con todos los detalles técnicos de infraestructura.

Planificación

- **Objetivo:** Evaluar la Seguridad de la aplicación Web Aurora Market mediante la identificación de Vulnerabilidades, el análisis de los Riesgos asociados y la propuesta de medidas de Mitigación.
- **Alcance:** La evaluación se limitará exclusivamente a la aplicación Web y a los componentes expresamente autorizados por Aurora Market, cualquier sistema o servicio no autorizado quedará fuera del alcance.
- **Permisos y condiciones:** se contará con una autorización formal antes de iniciar las pruebas. Se respetan las condiciones establecidas por Aurora Market de no interrumpir el servicio, no modificar ni eliminar la información real de los clientes, evitar afectar la disponibilidad y comunicar inmediatamente cualquier hallazgo crítico.
- **Metodología:** se seguirá una metodología estructurada de pentesting como OWASP que permitirá realizar la evaluación de forma organizada y sistemática facilitando la identificación, análisis y documentación de las vulnerabilidades encontradas. OWASP WSTG es la más indicada para analizar aplicación Web.

- **Recopilación de información previa:** Se analizará la información disponible sobre la aplicación Web para comprender su funcionamiento, identificar posibles áreas de interés y estructurar las pruebas necesarias para cumplir los objetivos establecidos.

Análisis de Recopilación de información Previa:

En esta etapa primero recopilaria la información que Aurora Market nos proporcione sobre su aplicación Web como la URL, los usuarios de prueba, los tipos de usuarios y cualquier información necesaria para conocer cómo funciona la aplicación. También utilizaría fuentes abiertas (OSINT) para buscar información pública relacionada con la aplicación siempre respetando el alcance autorizado.

El propósito de esta recopilación es conocer mejor el entorno antes de comenzar las pruebas y saber qué áreas debo revisar con mayor atención. Utilizaría Nmap para identificar puertos y servicios que estén dentro del alcance autorizado y herramientas como OWASP ZAP o Burp Suite para observar cómo se comunica la aplicación con el servidor, revisar las solicitudes y respuestas además conocer mejor su funcionamiento.

Toda esta información me ayudará a organizar las siguientes fases del Pentest y decidir qué puntos necesitan un análisis más profundo sin realizar todavía ninguna explotación.

- **Recursos Necesarios:** Se requerirá un equipo de trabajo, Herramientas de análisis de seguridad como Burp suite, OWASP ZAP Y Nmap. Un Acceso autorizado y cuentas de pruebas proporcionadas por Aurora Market, Documentación de autorización Formal y alcance y tiempo para realizar las pruebas y un canal de comunicación con la Empresa.

- **Programación del Pentest:** Se establecen previamente la duración y horarios de las pruebas Aurora Market hace énfasis en que sea en un horario de menor actividad para minimizar impactos sobre las operaciones y sus usuarios.

Análisis de la Programación del Pentest:

Para realizar el Pentest haría una sugerencia de Horario aproximado de 10:00 pm a 2:00am siempre que Aurora Market me confirme si a esas horas existe menor actividad de usuarios. Elegiría este horario porque algunas pruebas pueden generar tráfico adicional y prefiero reducir al máximo cualquier impacto sobre el funcionamiento normal de la aplicación. Antes de comenzar confirmaría con Aurora que ese horario esté autorizado y que exista un canal de comunicación por si ocurre alguna situación inesperada. Si la empresa determina que hay otro horario con menor actividad ajustaría las pruebas a esa ventana. De esta manera respeto una de las condiciones principales establecidas que es realizar las pruebas sin interrumpir el servicio ni afectar sus operaciones o usuarios.

Fases del Pentest.

- **Reconocimiento:** Se recopila información sobre la aplicación Web de Aurora Market para conocer el entorno, identificar funcionalidad y posibles puntos de entrada, siempre respetando el alcance establecido.

Análisis del Reconocimiento:

En esta fase buscaría conocer mejor la aplicación Web de Aurora Market antes de realizar pruebas profundas. Trataría de identificar las herramientas que utilizaría, las funcionalidades disponibles, los diferentes puntos de entrada de información, páginas de inicio de sesión y otros componentes que puedan ser importantes para la evaluación. También revisaría únicamente dentro del alcance autorizado que puertos y servicios están expuestos. Para esto utilizaría Nmap ya que permitiría identificar puertos abiertos y conocer qué servicios podrían estar

funcionando en ellos. Por ejemplo, encontrar los puertos 80 o 443 podría indicarme que existe un servicio Web disponible mediante HTTP o HTTPS.

En la Aplicacion utilizaría OWASP ZAP o Burp suite para observar las solicitudes y respuestas entre el navegador y el servidor e identificar parámetros, formularios y otras entradas que posteriormente puedan necesitar una revisión más detalladas.El Propósito en esta fase sería conocer y organizar la superficie que voy a evaluar, identificando posibles puntos de interés sin intentar explotar todavía ninguna vulnerabilidad.

- **Análisis de Vulnerabilidades:** Se Analizan los componentes y funcionalidades identificadas durante el reconocimiento para detectar posibles debilidades de seguridad que pueden representar un Riesgo para Aurora Market.Revisamos Autenticación, controles de acceso, configuraciones expuestas de la aplicación siempre dentro del alcance establecido.

Analisis de las vulnerabilidades:

En esta fase utilizaria la información obtenida durante el reconocimiento para buscar vulnerabilidades en la aplicación de Aurora Market. Me enfocaría en revisar aspectos como autenticación, los controles de acceso, las sesiones, los formularios y la forma en que la aplicación maneja los datos ingresados por los usuarios.

Utilizaria OWASP ZAP como apoyo para identificar posibles vulnerabilidades o configuraciones inseguras de la aplicacion .Tambien usaria Burp Suite para revisar con mayor detalle las solicitudes y respuestas entre el navegador y el servidor y analizar parámetros, cookies, sesiones entre otros elementos de la aplicación.

Los resultados obtenidos no los tomaría automáticamente como vulnerabilidades confirmadas, primero tendría que analizarlos y validarlos para descartar posibles

falsos positivos. Luego determinaría qué vulnerabilidades podrían representar un riesgo real para Aurora Market y cuales deberían tener mayor prioridad para continuar con la evaluación.

- **Explotación:** Aquí se comprueba de forma controlada si las vulnerabilidades identificadas pueden ser explotadas respetando en todo momento el alcance y las condiciones establecidas por Aurora Market, sin modificar información real y sin interrumpir el servicio ni afectar la disponibilidad de la aplicación.

Analisis de la Explotacion:

En esta fase tomaría únicamente las vulnerabilidades que fueron identificadas y validadas anteriormente para comprobar de manera controlada si realmente podrían ser aprovechadas y que impacto tendrían sobre la empresa.

Por Ejemplo si durante el análisis se detectara una posible falla de control de acceso , realizaría una prueba controlada utilizando las cuentas de prueba proporcionadas por Aurora Market para comprobar si un usuario puede acceder a información o funciones que no corresponden a su nivel de permiso.

Todas las pruebas se realizarían respetando el alcance y las condiciones. Evitará modificar o eliminar información real, afectar a usuarios o interrumpir el funcionamiento de la aplicación. Si durante la prueba encontrara una vulnerabilidad crítica , detendría esa prueba y la comunicaría inmediatamente a Aurora Market.

- **Post- Explotación:** Se analizará el Nivel de Acceso obtenido y el posible impacto de las vulnerabilidades explotadas respetando el límite establecido sin afectar las operaciones de la organización.

Analisis de la Post-Explotación:

En esta fase después de comprobar de manera controlada una vulnerabilidad, analizaría hasta dónde podría llegar un atacante si lograra aprovecharla y qué impacto tendría para la empresa.

Por ejemplo, si durante la prueba se logra acceder con una cuenta a información que ese usuario normalmente no debería poder ver, analizaría qué tipo de información quedó expuesta y qué riesgo representa para la empresa. No intentaría seguir avanzando innecesariamente ni acceder a otros sistemas fuera del alcance, porque el objetivo es demostrar el riesgo y no causar daño.

Documentaría lo ocurrido y las evidencias necesarias para explicar a la empresa que se logró comprobar, cuál podría ser el impacto y que debería corregirse, todo esto se realizaría respetando las condiciones acordadas y sin modificar o eliminar información real.

- **Informe:** Se documentarán las vulnerabilidades identificadas, las evidencias obtenidas, su nivel de riesgo e impacto así como las recomendaciones para su Mitigación. Este informe servirá como Registro de la evaluación realizada y permitirá al equipo de Aurora Market tomar las medidas necesarias para mejorar la seguridad de la aplicación.

Investigación.

Aquí debemos usar una metodología que nos proporcione una estructura para saber qué áreas revisar y cómo organizar las pruebas evitando trabajar de manera improvisada.

Para este Caso de Aurora Market usaremos OWASP web security testing Guide (WSTG) la cual resulta ser la más adecuada para este proyecto porque la aplicación Web es el objetivo principal de la evaluación y nos permite realizar pruebas de manera estructurada, sistemática y ordenada abarcando diferentes áreas de seguridad como autenticación, autorización, gestión de sesiones y validación de entradas.

Su utilización ayudaría a organizar las pruebas, reducir la posibilidad de omitir aspectos importantes y documentar adecuadamente los hallazgos obtenidos durante el Pentest.

